

OpenClaw法律风险与合规指南



自我介绍



刘洋

顾问

邮箱: liuyang@shihuilaw.com

电话: +86 178 8880 2705

刘洋律师的主要业务领域包括网络安全与数据保护、企业合规建设等，服务的客户涉及人工智能、互联网等多个行业。刘律师能够处理法律及前沿技术相结合的疑难问题，曾协助多家科技企业完成算法备案及人工智能大模型备案工作。

刘律师曾作为数据合规律师在头部互联网公司外派，熟悉AI及数据合规领域的行业实践，能够为企业提供落地可行的合规解决方案。刘律师亦曾参与著作《生成式人工智能法律实务：理论概览与和合规要点》的编写。

刘律师已获得中国网络安全审查认证和市场监管大数据中心“数据合规官”认证及“个人信息保护合规审计师”认证、中国网络空间协会个人信息保护合规审计人员认证、国家互联网应急中心CCSC-数据流通人员能力认证、工信部DCMM数据管理师认证、国际隐私专家协会IAPP颁发的CIPM（注册信息隐私经理）证书。刘律师被国际权威法律评级机构The Legal 500评为“年度大中华地区重点推荐律师：数据保护”（2024-2026）。

目录

- 01 OpenClaw法律风险
- 02 OpenClaw合规指南
- 03 新技术监管趋势

01 OpenClaw法律风险

- OpenClaw的技术特性
- OpenClaw的安全风险
- OpenClaw应用不同角色的风险
- 网络安全风险
- 数据安全风险
- 个人信息保护风险

经典AI (如ChatGPT)

Open Claw



交互方式：仅聊天回复



运行模式：单次会话



权限要求：低权限、与本地文件隔离



记忆能力：会话结束即遗忘



扩展性：功能固定，难以扩展



交互方式：执行操作（文件、命令、API）



运行模式：长期运行服务（7X24小时）



权限要求：高权限、系统级、可执行、可操作



记忆能力：持久记忆



扩展性：Skills插件生态

机构	风险提示
国家互联网应急中心（CNCERT）	3月10日，国家互联网应急中心（CNCERT）发布《关于OpenClaw安全应用的风险提示》
工业和信息化部网络安全威胁和漏洞信息共享平台	2月6日，工业和信息化部网络安全威胁和漏洞信息共享平台发布《关于防范OpenClaw开源AI智能体安全风险预警提示》
国家工业信息安全发展研究中心	3月13日，国家工业信息安全发展研究中心发布《关于工业领域OpenClaw应用的风险预警通报》
中国互联网金融协会	3月15日，中国互联网金融协会发布《关于OpenClaw应用安全的风险提示》

关于OpenClaw安全应用的风险提示

原创 CNCERT 国家互联网应急中心CNCERT 2026年3月10日 19:02 北京

近期，OpenClaw^Q（“小龙虾”，曾用名Clawdbot、Moltbot）应用下载与使用情况火爆，国内主流云平台均提供了一键部署服务。此款智能体软件依据自然语言指令直接操控计算机完成相关操作。为实现“自主执行任务”的能力，该应用被授予了较高的系统权限，包括访问本地文件系统、读取环境变量、调用外部服务应用程序编程接口（API）以及安装扩展功能等。然而，由于其默认的安全配置极为脆弱，攻击者一旦发现突破口，便能轻易获取系统的完全控制权。

前期，由于OpenClaw智能体的不当安装和使用，已经出现了一些严重的安全风险：

1.“提示词注入”风险。网络攻击者通过在网页中构造隐藏的恶意指令，诱导OpenClaw读取该网页，就可能致其被诱导将用户系统密钥泄露。

2.“误操作”风险。由于错误的理解用户操作指令和意图，OpenClaw可能会将电子邮件、核心生产数据等重要信息彻底删除。

3.功能插件（skills）投毒风险。多个适用于OpenClaw的功能插件已被确认为恶意插件或存在潜在的安全风险，安装后可执行窃取密钥、部署木马后门软件等恶意操作，使得设备沦为“肉鸡”。

4.安全漏洞风险。截止目前，OpenClaw已经公开曝出多个高中危漏洞，一旦这些漏洞被网络攻击者恶意利用，则可能导致系统被控、隐私信息和敏感数据泄露的严重后果。对于个人用户，可致隐私数据（像照片、文档、聊天记录）、支付账户、API密钥等敏感信息遭窃取。对于金融、能源等关键行业，可致核心业务数据、商业机密和代码仓库泄露，甚至会使整个业务系统陷入瘫痪，造成难以估量的损失。

CIC 工信安全 | 国家工业信息安全发展研究中心

邮箱登录 | 官方微博

首页

重点科研

研究成果

测评认证

研究机构

党群工作

招贤纳士

关于我们

所在位置：首页 > 通知公告

关注 | 关于工业领域OpenClaw应用的风险预警通报

时间：2026-03-16

一、基本情况

近期，开源AI智能体OpenClaw（俗称“龙虾”）以其颠覆性的“人机交互”模式，在技术社区及公众领域引发广泛关注。OpenClaw（曾用名Clawdbot、Moltbot）是一款开源AI智能体，可依据自然语言指令直接操控计算机完成相关定制化操作，具备持久记忆、主动执行等技术能力，目前正加速在工业领域研发设计、生产制造、运维管理等环节部署应用。然而，由于OpenClaw存在信任边界模糊、多渠道统一接入、大模型灵活调用、双模持久化记忆等特点，一旦缺乏有效的权限控制策略或安全审计机制，可能因指令诱导、供应链投毒等被恶意接管，造成工控系统失控、敏感信息泄露等一系列安全风险，严重危害工业企业正常生产运行。

二、风险分析

工业领域具有数据敏感度高、系统集成度高、工业场景复杂、生产流程严苛等特点，企业在应用OpenClaw赋能提升生产效率、优化流程管理的同时，也因其高权限设计、自主决策特性与工业场景适配性偏差等问题，面临系统越权失控、敏感信息泄露、外部攻击面增加等潜在风险隐患。

中国互联网金融协会
National Internet Finance Association of China

首页

协会概况

协会动态

政策法规

行业标准

行业自律

协会会员

行业研究

会议培训

您当前的位置：协会动态 > 协会新闻

关于OpenClaw在互联网金融行业应用安全的风险提示

2026年03月15日

角色	主要行为	法律风险	依据
企业部署方	高权限失控，导致数据泄露、系统瘫痪	违反网络安全、数据安全保护义务的风险	《网络安全法》《数据安全法》
	个人信息泄露，相关数据自动上传至境外模型	违反个人信息保护义务的风险	《个人信息保护法》
	恶意插件使设备成跳板、被黑客控制作为“肉鸡”节点，引发网络攻击	网络服务提供者不履行法律、行政法规规定的信息网络安全管理义务	《刑法》《网络安全法》
	处理商业秘密、核心业务数据	商业秘密泄露，面临司法举证困难	《反不正当竞争法》
二次开发者	未遵守MIT协议要求，擅自闭源分享或篡改版权信息	侵权著作权	《著作权法》
	在OpenClaw基础上开发新的AI智能体，并以自身的名义对外提供服务	违反人工智能监管的风险	《生成式人工智能服务管理暂行办法》
代养的用户	将设备交由他人用于违法活动，成为黑灰产的“帮凶”	涉嫌帮助信息网络犯罪活动罪	《刑法》

■ 《网络安全法》修订增加处罚力度

- 引入“造成严重后果或特别严重后果”的高额处罚。造成“关键信息基础设施丧失主要功能等特别严重危害网络安全后果”的，单位最高可以处1000万罚款
- 一般违法行为直接处罚。对于违反网络安全保护义务的一般违法行为，新《网络安全法》可以直接进行罚款处罚，无需事先由主管部门责令整改
- 扩展了责任追究主体。新《网络安全法》对于不履行网络安全保护义务的，不仅处罚“直接负责的主管人员”，还处罚“其他直接责任人员”

■ 已知高危漏洞且未及时修复的“零容忍”处罚

案例名称	处罚案例	具体处罚
广东某科技股份有限公司未修复系统漏洞被攻击案	该企业涉事系统存在任意文件上传漏洞，遭受勒索软件攻击，该企业当天发现后仅重装系统， 未修复系统漏洞 。其后，攻击者利用该漏洞上传远程控制木马，将登录页面篡改违法有害内容	网信部门已依法责令其改正，并予以警告、罚款处罚
新疆某互联网科技有限公司未修复系统漏洞被攻击案	该企业上述网站 存在安全缺陷和漏洞 ，相关网页源代码php文件被恶意篡改	网信办已依法责令其改正，并予以警告处罚
江苏苏州某公司未采取技术防护措施被攻击案	短信群发系统被攻击冒用，并发送诈骗短信27000余条。江苏公安机关网安部门查明因相关短信群发平台未进行等保备案测评， 未采取技术防护措施，导致被犯罪嫌疑人攻击控制 ，短信服务被冒用滥发	当地公安机关已依法对该系统建设运维方予以行政处罚并责令限期改正

■ 工业领域

- 工业企业在 OpenClaw 过程中，感染恶意插件且未设置安全防护策略，攻击者可直接利用恶意插件窃取工业图纸、API 密钥等核心机密信息
- 由于 OpenClaw 对指令的理解精度不稳定，可能在理解操作指令和意图上存在偏差，错误调用数据导出或内容发布功能，并利用其已获取的系统权限，将本应隔离保存的关键工艺参数、生产数据等内部敏感信息，直接发布在互联网上

数据类别	数据子类	数据基本特征与描述
三、工业类	14. 电力	大型水电站，大型抽水蓄能电站，核电站，单机（套）容量在 100 万千瓦及以上、装机总容量 300 万千瓦及以上火力发电站，500 千伏（不含）以上变电站（开关站）、换流站等电力基础设施以及远程调度控制中心的设计施工图纸资料（含精度 100 米内位置坐标）；特级电力用户电力消费的原始数据等。
	15. 电子信息	电子信息行业先进技术、集成电路先进设计和制造技术、重大计算装备设计数据、算法和软硬件架构以及重要电子元器件设备国产化率等数据。如关键芯片、操作系统、大型软件等基础电子信息产品参数，源代码，集成电路布图，产品测试数据，产品面向国防军工、政务等领域销售和服务情况等。
	16. 民用核设施	一旦遭到篡改、泄露或者非法利用，可能影响核材料或者核设施安全的数据。如民用核设施科研中的试验或者测试数据，核设施相关设计和制造工艺，核设施运行监控数据等。
	17. 工业装备	反映国家高端制造水平，体现国家在工业领域核心竞争力的数据。如应用于军事、航空航天等领域的高技术装备研发和生产情况，大型装备或者具有核心技术的重要装备的研发、生产情况等。
	18. 工业互联网和工业控制系统	规模以上工业企业使用的工业互联网或工业控制系统安全运行保障数据。如年产值 4 亿元以上工业企业使用的工业互联网或者工业控制系统的参数及运行、维护、测试数据；城市供水、供气、供热自动控制系统的参数及运行、维护、测试数据等。
	19. 智能汽车	反映重要敏感区域的地理位置、作业状况，以及 10 万以上智能汽车消费者相关敏感个人信息的数据。如智能汽车运行过程中获取的军事管理区、国防军工单位、县级以上党政机关等重要敏感区域的地理信息、人员流量、车辆流量数据以及 OTA 数据等。

■ 金融领域

- OpenClaw智能体具备持久记忆功能，运行过程中产生的数据持续存储在本地会话记录和记忆文件中，在其调用大模型API接口或其他操作时，**相关数据可能传输至第三方**
- 金融场景涉及**征信数据、信贷审批材料、交易流水等高度敏感数据**，上述数据进入AI处理链路后，其可访问范围和留存周期可能超出原有业务目的的必要范围，引发金融数据管理合规风险

数据类别	数据子类	数据基本特征与描述
四、金融类	20.银行	一旦遭到泄露，可能会威胁国家安全或者银行机构自身安全，或者100万以上客户安全的数据。如银行安保数据，重要企事业单位账户信息、贷款数据、交易数据等。
	21.保险	一旦遭到泄露，可能会威胁100万以上客户安全，或者威胁国家安全或者重要单位、设施运行安全的数据。如涉及国家安全的重要设施、装备、人员的保险和理赔数据，保险机构处理的承担国家重大工程或者国民经济社会发展重要领域建设项目的企事业单位投保或者理赔数据等。
	22.融资租赁	一旦遭到泄露或者被他国利用，可能会威胁100万以上客户安全，或者影响相关企业运营的数据。如涉及党政机关、国防军工企业的融资租赁数据等。

风险特征	法律风险
后台自动化处理个人信息，未以清晰方式告知处理目的、范围、保存期限，更无法取得同意	违反个人信息处理告知同意的要求
持久化存储上下文	违反个人信息处理的最小必要原则
支持调用境外大模型（Claude、GPT等，自动上传本地数据）	违反跨境传输个人信息的合规要求
自动化任务中可能未经授权将本地文件、个人信息上传至第三方云端/API	个人信息泄露



02 OpenClaw合规指南

- 提供一键部署能力的服务方
- 企业部署方

■ 提供一键部署能力的服务方

➤ 服务模式

- 服务方仅提供一键部署能力，并未实际参与到提供 OpenClaw 的服务，亦未改变 OpenClaw 的底层架构和安全能力

➤ 合规指南

- 不视为提供 OpenClaw 的 AI 服务，但应参考权威机构风险预警，做好用户使用 OpenClaw 功能的风险提示

d. 若您允许飞书 OpenClaw 项目访问并操作您在第三方网站或产品服务的账户，表示飞书 OpenClaw 项目已获得您的合法授权，且该行为不违反第三方规定、亦不会使我们承担额外义务。对于因第三方服务通过 AI 辅助操作而检测、限制或终止您的访问权限所导致的任何后果，由您个人承担，您与第三方的任何纠纷、隐私协议约束及越权后果，完全由您单方负责解决，与我们无关。

e. 受限于现有技术不可避免的局限性，智能助手在执行操作任务时，可能会出现非预期的操作偏离或异常的重复调用。您在智能助手运行期间应妥善监控并保持合理关注，并在必要时及时予以人工干预或中止。若因前述技术原因导致您所配置的第三方服务或 API 接口产生超出预期的计费消耗，相关超额资费及资金损失均由您自行承担，我们对此不承担任何补偿或赔偿责任。

f. 为保障本服务的安全合规运行，我们在内置了相关安全策略与操作限制。请您知悉并承诺，严禁以任何方式擅自修改、删除或试图绕过上述包含安全限制的文件。若您因篡改前述文件导致本服务突破原有的安全护栏或操作权限，由此引发的任何数据损毁、财产损失或第三方侵权索赔等一切不利后果及法律责任，均由您单方完全承担，我们对此不承担任何形式的赔偿责任。

您确认并承诺，如您自行安装或使用任何第三方软件或服务（包括您下载安装开源社区或第三方 Skills 等），您需自行遵守第三方软件或服务的服务协议或使用规则。特别提醒您，您需谨慎选择第三方 Skills，充分评估后进行使用，小米对您使用第三方软件或服务的行为及导致的任何后果不承担任何责任。

您须理解并同意，在使用第三方服务时，第三方可能会对您数据进行读取，小米不保证通过第三方系统或第三方软件支持实现的结果的安全性、准确性、有效性，您应审慎判断，由此引发的任何争议及损害，小米不承担任何责任。

■ 提供一键部署能力的服务方

➤ 服务模式

- 服务方仅提供一键部署能力，并未实际参与到提供 OpenClaw 的服务，亦未改变 OpenClaw 的底层架构和安全能力

➤ 合规指南

- 根据个人信息保护一般要求，披露使用 OpenClaw 功能涉及的数据处理以及权限使用

权限名称	使用目的	是否可选	使用场景	拒绝影响
网络访问权限	用于连接QClaw服务器进行账号注册/登录验证，以及向大模型发送输入内容、接收输出内容，访问第三方软件或在线服务	否（必需）	注册登录、智能对话、智能操作	将无法使用QClaw的任何在线功能，产品无法正常运行
系统剪贴板读取权限	用于在用户主动执行粘贴操作时，读取剪贴板中的内容并填入智能对话输入框	是（可选）	用户在智能对话输入框中执行“粘贴”操作时触发	您将无法通过粘贴方式向对话框输入内容，但仍可通过手动键入、拖拽文件等其他方式输入内容
本地文件读取权限	用于在用户主动上传或拖拽文件（如文档、图片等）至对话框时，读取该文件内容以提供智能对话服务	是（可选，按需触发）	用户在智能对话中上传文件、图片时触发	您将无法向对话框发送本地文件或图片，但仍可通过文字输入等方式使用对话服务

■ 企业部署方

大厂推出claw类产品采取的控制措施



■ 企业部署方



安全管理制度与使用规范

- **明确边界**：划定运行/禁止的使用场景、数据范围和操作类型
- **规范流程**：建立内部使用规范和审批流程，新应用或高权限功能需经安全评估和管理层批准



权限管理与边界控制

- **最小权限**：所有智能体账号遵循最小必要权限原则配置
- **访问控制**：限定智能体可访问的文件目录、网络域、数据库表等
- **高权限管控**：对高权限智能体实行严格的多因素认证和操作审批



基础网络与环境安全防护

- **网络隔离**：禁止智能体直接暴露在公网，通过防火墙、VPN限制访问
- **入侵防御**：启用主机入侵防御、恶意流量检测，抵御网络攻击
- **系统更新**：定期更新运行环境补丁，消除系统漏洞



供应链安全与代码管理

- **第三方审核**：引入新技能模块需经安全审核和测试
- **版本更新**：定期检查并更新现有技能和依赖库的版本

■ 企业部署方



运行监控与审计追踪

- **持续监控**: 监控行为日志、决策输出及异常事件，实时掌握状态
- **审计日志**: 对关键操作生成防篡改日志，确保可追溯



关键操作保护策略

- **二次确认**: 高危操作（如删库、改配）需人工多重签批
- **模拟演练**: 不可逆转操作先行模拟，验证安全无误后执行
- **范围限定**: 严格限定高影响操作的时间窗口和执行范围



凭证与密钥管理

- **安全存储**: 敏感凭据严禁硬编码，必须使用安全管理系统注入
- **及时回收**: 智能体任务结束后，立即销毁或回收临时密钥



人员培训与应急演练

- **安全培训**: 定期对全员进行安全意识和技能培训
- **责任意识**: 规范操作流程，杜绝违规误用
- **应急演练**: 制定预案并定期开展实战演练

03 新技术监管趋势

- AI立法思路：“小切口”，针对具体产品/技术
- 人工智能服务提供者的合规义务

- 立法整体上不贪大求全，针对具体产品、场景（如算法推荐、深度合成、人脸识别、生成式人工智能服务）做“小切口立法”，立法工具箱中的制度如备案、安全评估组合适用，技术性较强的要求如内容标识在落地中会有配套国家标准

2025.12 人工智能拟人化互动服务管理暂行办法（征求意见稿）

2025.04 网络安全技术 生成式人工智能服务安全基本要求

2025.03 人脸识别技术应用安全管理办法

2025.03 人工智能生成合成内容标识办法

2025.02 （国家标准）网络安全技术 人工智能生成合成内容标识方法

2023.09 科技伦理审查办法（试行）

2023.07 生成式人工智能服务管理暂行办法

2022.11 互联网信息服务深度合成管理规定

2021.12 互联网信息服务算法推荐管理规定

2021 数据安全法、个人信息保护法

		生成式AI	深度合成	算法推荐
内容安全义务	承担内容生产者责任，避免违法不良信息发布	√	√	√
	违法内容检测处置	√	√	√
	建立健全投诉举报机制，提供便捷的公众入口	√	√	√
备案评估义务	算法备案	√	√	√
	公安安全评估	√	√	√
	审核评估验证算法机制机理	√	√	√
数据保护义务	履行个人信息保护义务	√	√	√
	加强用户模型和用户标签管理	√	√	√
	向用户提供不针对个人的选项或提供便捷的关闭选项	√	√	√
用户权益保护	算法公平，保障消费者平等交易、劳动者权益、便利老人等用户权益	√	√	√
	防沉迷、未成年保护义务	√	√	√
	生成内容（声音、人脸、图像、视频等）标识	√	√	
用户管理义务	与用户签订服务协议约定合理使用	√	√	
	训练数据来源合法安全	√	√	
知识产权	使用者的输入信息和使用记录保护	√		
研发及服务质量义务	训练数据标注相关义务	√		
	提供稳定服务	√		
大模型备案义务	网信安全评估（生成式人工智能服务备案/登记）	√		

第一届龙虾 AI 大会

ClawCon 2026

OpenClaw · 聊虾 · 玩虾 · 养虾

THANKS



Young

北京 海淀



扫一扫上面的二维码图案，加我为朋友。

